

Attack Surface Analysis Triage Procedure

Revision

Version 1
5/28/25 8:21 PM

SME

Charles Wilson

Abstract

This document describes the procedure used to perform the attack surface analysis triage activity described in the AVCDL secondary document **Attack Surface Analysis Report** [\[6\]](#).

Group / Owner

Security / Security Architect

Motivation

This document is motivated by the need to identify design deficiencies related to cybersecurity as early in the product development process as possible. This is necessary given the nature of safety-critical, cyber-physical systems, subject to certifications such as **ISO/SAE 21434** and **ISO 26262**.

Note: Within the context of this document, the terms ***security*** and ***cybersecurity*** are used interchangeably. It is presumed that the term ***security*** is being used in reference to ***cybersecurity*** and not ***physical security***.

Audience

The audience of this document is the cybersecurity practitioner who will be conducting the cybersecurity attack surface analysis triage.

Completeness of Output

Since attack surface analysis is an as-is analysis, it is critical to ensure that the information gathered is as accurate and complete as possible. As with any cybersecurity assessment, it is not the place of the cybersecurity SME to make assumptions on the part of engineering. All information should be sourced from and confirmed by the owner of the element under consideration.

When information is not available for either a given section of the template or parts thereof, this should be noted. Major omissions should be recorded in the cybersecurity risk register.

Disposition of Output

Once completed, the generated output should be managed in the organization's document management system (DMS) as a document of record.

Entry Criteria

This document assumes that the reader understands the purpose of cybersecurity attack surface analysis. Further, that the reader has read and understood the AVCDL **Attack Surface Analysis Report** secondary document.

Prerequisites – Development SME

Qualifications

It is required that the development SME is both a qualified and trained development SME with expertise in the element under consideration.

Note: The specific qualifications and training of development SMEs necessary to assert expertise in providing accurate information regarding the element under consideration is outside the scope of this document.

Note: The development group is responsible for determining and making available the appropriate SME for the analysis of the element under consideration.

Knowledge

It is required that the development SME have expertise in the element under consideration.

Prerequisites – ASA SME

Qualifications

It is required that the ASA SME is both a qualified and trained security architect (shown above on title page as **Owner**) as defined by the **NIST NCWF** role SP-ARC-002 and detailed in section **12.7 Security Architect** of the AVCDL primary document [\[1\]](#).

Knowledge

It is required that the ASA SME understands the purpose of cybersecurity attack surface analysis.

Background Information

It is required that the ASA SME has read and understands the AVCDL **Attack Surface Analysis Report** [\[6\]](#) and **Security Requirements Taxonomy** [\[3\]](#) secondary documents. Additionally, that the cybersecurity SME has taken training relevant to this activity.

Prerequisites – Input Materials

It is required that the threat candidates, created in the ASA **analysis** activity, be available.

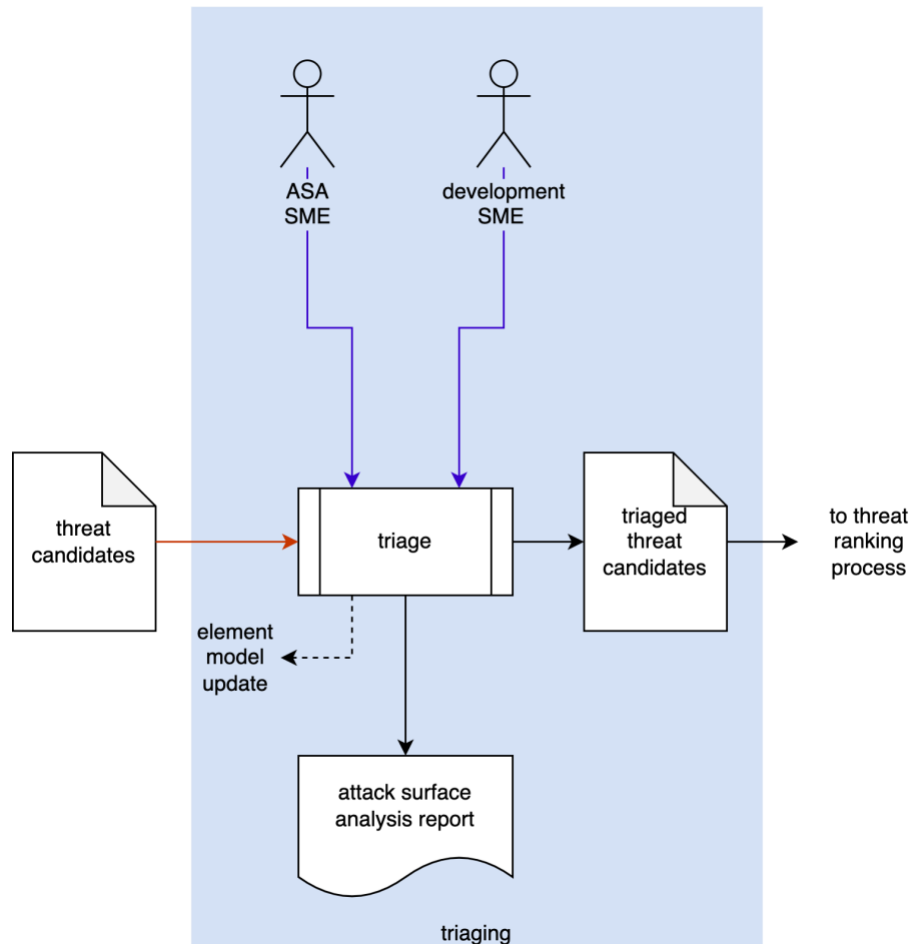
Additionally, it is required that the ASA model for the element under consideration, created in the ASA **model creation** activity, be available.

It is recommended that the functional and cybersecurity requirements for the element under consideration be available.

Note: The relationship between functional and cybersecurity requirements is covered in **Element-level Security Requirements** [\[7\]](#) AVCDL secondary document.

Triage Activity

The workflow diagram for the triage activity of the **Attack Surface Analysis Report** is shown below.

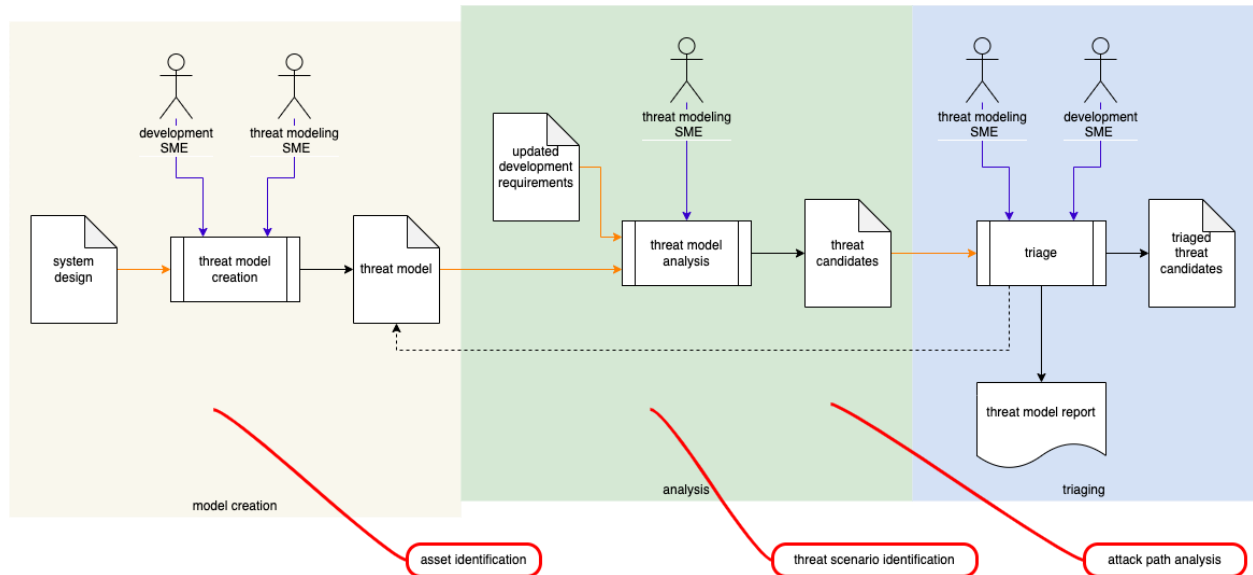


The **ASA SME** works with the **development SME(s)** to perform an initial triage of the **threat candidates**. This triage will yield one of three results:

1. A threat candidate is determined to be plausible. It will be marked as such and where possible given a preliminary severity (where the severity designation may be used as a **bug bar** ^[8]).
2. A threat candidate exposes incomplete / incorrect information forming the model. The model will need to be updated, and analysis redone.
3. A threat candidate is determined to be a non-issue due to circumstances not captured by the model. It will be marked as such and removed from consideration.

Theory

The AVCDL **Understanding TARA in an AVCDL Context** [5] elaboration document is intended to illustrate how the AVCDL's threat modeling activities map into established standards. It does not, however, identify any equivalents to the threat modeling **triage** activity with respect to other standards. This is shown in the following diagram. The AVCDL considers the **triage** activity to be a necessary precursor to the **threat prioritization process** [2]. The same holds true for the AVCDL's attack surface analysis **triage** activity.



Goal

The goal of triaging the threat candidates resulting from the ASA's model analysis is to eliminate any candidates which are present due to either inaccuracy of the model or circumstances present within the context of the element which cannot be captured by the model directly.

Methodology

Fundamental Approach

The fundamental approach to threat candidate triage is straightforward. Each of the issues (threat candidates) identified in the ASA **analysis** activity are reviewed to determine whether they are valid. This determination is recorded and, where necessary, a justification provided.

The determination may be one of the following:

- valid
- insufficient model
- non-issue

Valid

When properly executed the ASA model analysis will result in threat candidates that identify actual deficiencies of the element with respect to proper attack surface behavior.

Note: If the vast majority of the threat candidates are not determined to be valid, there is either an issue with the execution of the **analysis** or **triage** process.

Insufficient Model

This determination is appropriate when the development SME indicates that the threat candidate being triaged is invalid, where the cause stems from either incomplete or inaccurate information having been provided during the creation of the model. The model will need to be updated to include new information. Additionally, the analysis will need to be performed again to ensure that the updated model yields the appropriate analysis.

Non-issue

This determination is appropriate when the development SME indicates that the threat candidate being triaged is valid, but because of information not contained within the model. This differs from both incomplete and inaccurate information having been provided during the creation of the model. In this case there is typically a higher level abstraction at play. The model will need to be updated to include a note regarding how this abstraction impacts the element. Additionally, the analysis will need to be performed again to ensure that the updated model yields the appropriate analysis.

Attack Surface Analysis Triage Template

The threat candidate triage activity may be documented using the **AVCDL attack surface analysis triage template** Microsoft Excel workbook [\[4\]](#).

Note: Other forms of documentation are permissible so long as they provide the information laid out in this document.

There are five sheets in the workbook. They are:

- [Cover sheet](#)
- [Revision history](#)
- [Reference documents](#)
- [Triage determination](#)
- [Legend](#)

These will be addressed in turn.

Duplication of Rows in the Various Sheets

When there is the need to add rows to the various sheets of the workbook, be sure to duplicate an existing row. This is because validation checks are attached to some of the cells which also enables the use of dropdown lists.

Cover Sheet

The **cover sheet** of the workbook is shown below:

Attack Surface Analysis - Triage								
Element Name	Element Name							
Element Scope	Element Scope							
Vendor Name	Vendor Name							
ASA SME	ASA SME							
Development SME	Development SME							
Date	27-Aug-2000							
Model Revision	1							

Fields to be completed are shown in **red**.

Element Name

The **element name** is the element whose ASA issues are being triaged.

Element Scope

The scope of the element is left to the discretion of the customer. Examples of element scopes include system, sub-system, component, component software (non-OS), and component OS.

Note: In this context, **the customer** refers to the entity requiring the activity.

Vendor Name

This is the name of the vendor responsible for the element under consideration.

ASA SME

This is the ASA subject matter expert triaging the threat candidates.

Development SME

This is the development subject matter expert providing information about the element.

Date

This is the date when the element's ASA model analysis triage was created or updated. The date should be updated whenever the document is updated.

Revision

This is the revision number of the document. The revision number is a monotonic and increasing integer, starting at 1. It should be incremented every time the document is updated.

Revision History

The **revision history** sheet of the workbook is shown below:

Revision History		
Revision	Author	Description
1		initial revision

Revision

The **revision** corresponds to that listed on the cover sheet.

Author

The **author** corresponds to the ASA SME listed on the cover sheet.

Description

This is a brief description of changes made to the ASA model analysis triage since it was last updated.

Reference Documents

Note: These references are those necessary for the creation of the element's ASA issue triage.

Note: References to the element's ASA model, cybersecurity requirements documents, and ASA model analysis should be included.

The **references** sheet of the workbook is shown below:

Reference Documents		
Name	Description	Location

Name

This is the name of the document being referenced.

Description

This is a brief description of the document being referenced.

Location

This is the location of the document being referenced. It may be a physical location or a URL.

Triage Determination

The **triage determination** sheet of the workbook is shown below:

Triage Determination			
issue ID	determination	justification	notes

Issue ID

This is the unique element attack surface analysis issue ID.

Determination

This is the determination of the issue's triage. It may be one of the following:

- valid
- insufficient model
- non-issue

Note: The meanings of these were covered earlier in this document.

Justification

This is the justification for the selected determination.

Note: If the determination is that the issue is **valid**, no justification is required.

Notes

This is a general notes field.

Legend

The **legend** sheet of the workbook is shown below:

determination
valid
insufficient model
non-issue

The **legend** sheet information is used to make the completion of the document easier by providing dropdown lists for common values. It also ensures that spelling errors do not creep into the generated material.

Note: The legend sheet should not be edited. If an unlisted value is required, the template should be separately revised.

Exit Criteria

This procedure is considered complete once the generated output has been entered into the organization's DMS as a document of record.

Note: The processes and procedures for entering documents into the DMS, or the updating thereof, are outside the scope of this document.

References

1. **AVCDL** (AVCDL primary document)
2. **Threat Prioritization Plan** (AVCDL secondary document)
3. **Security Requirements Taxonomy** (AVCDL secondary document)
4. **AVCDL attack surface analysis triage template** (AVCDL template)
5. **Understanding TARA in an AVCDL Context** (AVCDL elaboration document)
6. **Attack Surface Analysis Report** (AVCDL secondary document)
7. **Element-level Security Requirements** (AVCDL secondary document)
8. **The Security Development Lifecycle** (Howard and Lipner)